MITRE ATLAS | AML.CS0021 - ChatGPT Conversation Exfiltration

Entry Information

ID:
AML.CS0021

Type:
Case-Study

Name:
ChatGPT Conversation Exfiltration

URL:
https://atlas.mitre.org/studies/AML.CS0021/

Incident Date:
2023-05-01

Target:
OpenAI ChatGPT

Actor:
Embrace The Red

Description

[Embrace the Red](https://embracethered.com/blog/) demonstrated that ChatGPT users' conversations can be exfiltrated via an indirect prompt injection. To execute the attack, a threat actor uploads a malicious prompt to a public website, where a ChatGPT user may interact with it. The prompt causes ChatGPT to respond with the markdown for an image, whose URL has the user's conversation secretly embedded. ChatGPT renders the image for the user, creating a automatic request to an adversary-controlled script and exfiltrating the user's conversation. Additionally, the researcher demonstrated how the prompt can execute other plugins, opening them up to additional harms.

Attack Procedure:
[AML.T0065] LLM Prompt Crafting: The researcher developed a prompt that causes ChatGPT to include a Markdown element for an image with the user's conversation embedded in the URL as part of its responses.
[AML.T0079] Stage Capabilities: The researcher included the prompt in a webpage, where it could be retrieved by ChatGPT.
[AML.T0078] Drive-by Compromise: When the user makes a query that causes ChatGPT to retrieve the webpage using its `WebPilot` plugin, it ingests the adversary's prompt.
[AML.T0051.001] Indirect: The prompt injection is executed, causing ChatGPT to include a Markdown element for an image hosted on an adversary-controlled server and embed the user's chat history as query parameter in the URL.
[AML.T0077] LLM Response Rendering: ChatGPT automatically renders the image for the user, making the request to the adversary's server for the image contents, and exfiltrating the user's conversation.
[AML.T0053] AI Agent Tool Invocation: Additionally, the prompt can cause the LLM to execute other plugins that do not match a user request. In this instance, the researcher demonstrated the `WebPilot` plugin making a call to the `Expedia` plugin.
[AML.T0048.003] User Harm: The user's privacy is violated, and they are potentially open to further targeted attacks.

References

- ChatGPT Plugins: Data Exfiltration via Images & Cross Plugin Request Forgery — https://embracethered.com/blog/posts/2023/chatgpt-webpilot-data-exfil-via-markdown-injection/